Security Requirements and How to Check Them

ID	Requirement	What a passing check looks like	Priority
SEC-01	Authenticate every protected operation.	An unauthenticated request receives no account, transaction, or loan data.	High
SEC-02	Check role permissions and record ownership on the server.	Changing another customer's identifier results in denial for both read and write requests.	High
SEC-03	Use least privilege and deny access by default.	Automated tests confirm each role can do only the actions explicitly assigned to it.	High
SEC-04	Validate input and use safe database access.	Zero, negative, malformed, or unsupported transaction values are rejected; invalid input cannot change data.	High
SEC-05	Keep financial operations atomic and consistent.	A forced failure during a transfer leaves neither a partial debit nor a partial credit.	Medium
SEC-06	Prevent duplicate transaction processing.	Submitting the same transaction request twice creates no duplicate posting.	Medium
SEC-07	Protect data in transit and at rest.	TLS configuration, storage settings, backup protection, and key access are reviewed and recorded.	High
SEC-08	Record meaningful security and financial events.	Test events appear in a protected log without passwords, session tokens, or excessive personal data.	Medium
SEC-09	Use safe defaults and limit abusive traffic.	Debug mode and sample credentials are disabled; repeated login attempts trigger the defined control.	Medium
SEC-10	Prepare for recovery and maintenance.	A backup can be restored in a recorded test; dependencies and security settings have an owner and review process.	Medium